

PRIVACY AT SCALE



Roblox's Infrastructure for **Honoring** User Privacy Rights



Who are we



We build the infrastructure that operationalizes and fulfills user privacy rights at scale — **safely, completely, and provably.**



Hao Zhang

Engineering Manager,
Privacy Infrastructure



Yiwen Luo

Principal Engineer,
Privacy Infrastructure

Agenda

1



Problem Statement

2



Privacy infrastructure: A Redesigned Federated System

3



New Experience: Privacy Workflows in Distributed Systems

4



Security Discussion: Threats, Reliability, and Trade-offs

5



Future work & Conclusion



01

Problem Statement

The challenge that pushed us
to rethink everything.



PRIVACY RIGHTS SOUND SIMPLE



Delete me.



Give me a copy.



Correct my record.

SIMPLE FOR THE USER



600 SERVICES



ONE REQUEST → HUNDREDS OF SYSTEMS



Privacy rights are easy to ask for.

They're extremely hard to execute.

ROBLOX AT SCALE

 **132M**

Daily active users · Q1 2026



600+

services



8

storage
engines

THE HARD WORK IS GROWING FASTER

~1.6x

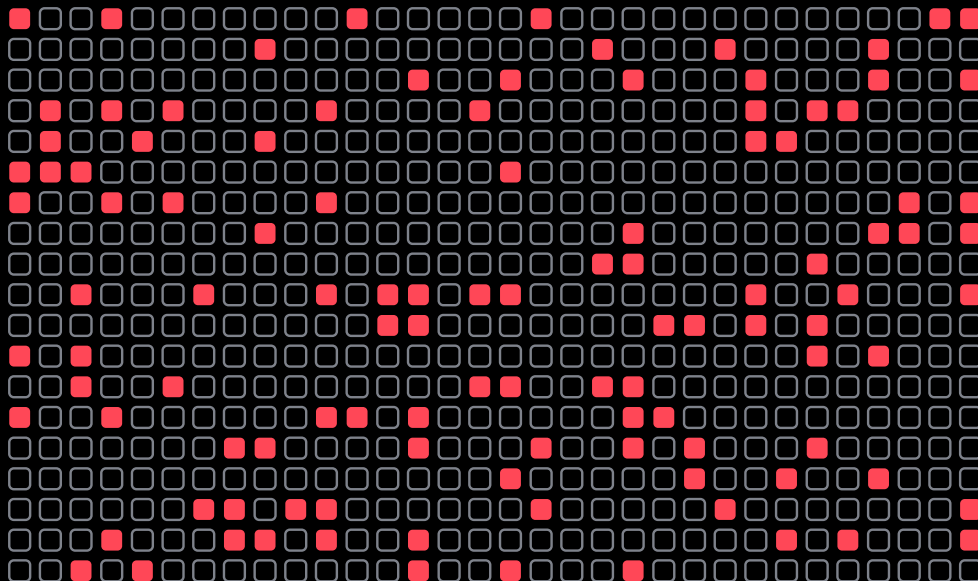
YoY user growth

vs.

~3.5X

YoY privacy request
growth

□ = 1 service / datastore ■ = Contains personal data (~20%)



SQL



NoSQL



Object
Storage



Columnar
Warehouse



Key
Value



Search
Engine



Graph
DB



In-Memory
Store

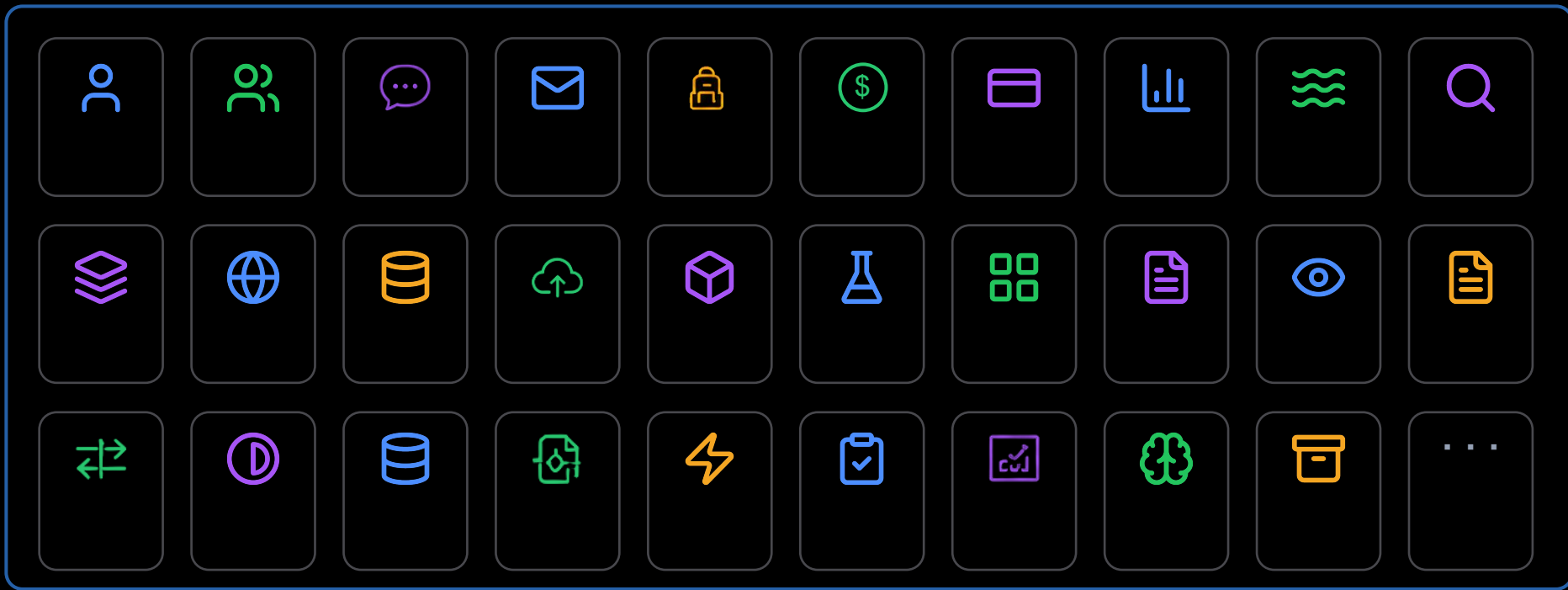
8 STORAGE ENGINES ACROSS THE FLEET



THE WORKLOAD OUTRUNS THE PLATFORM.

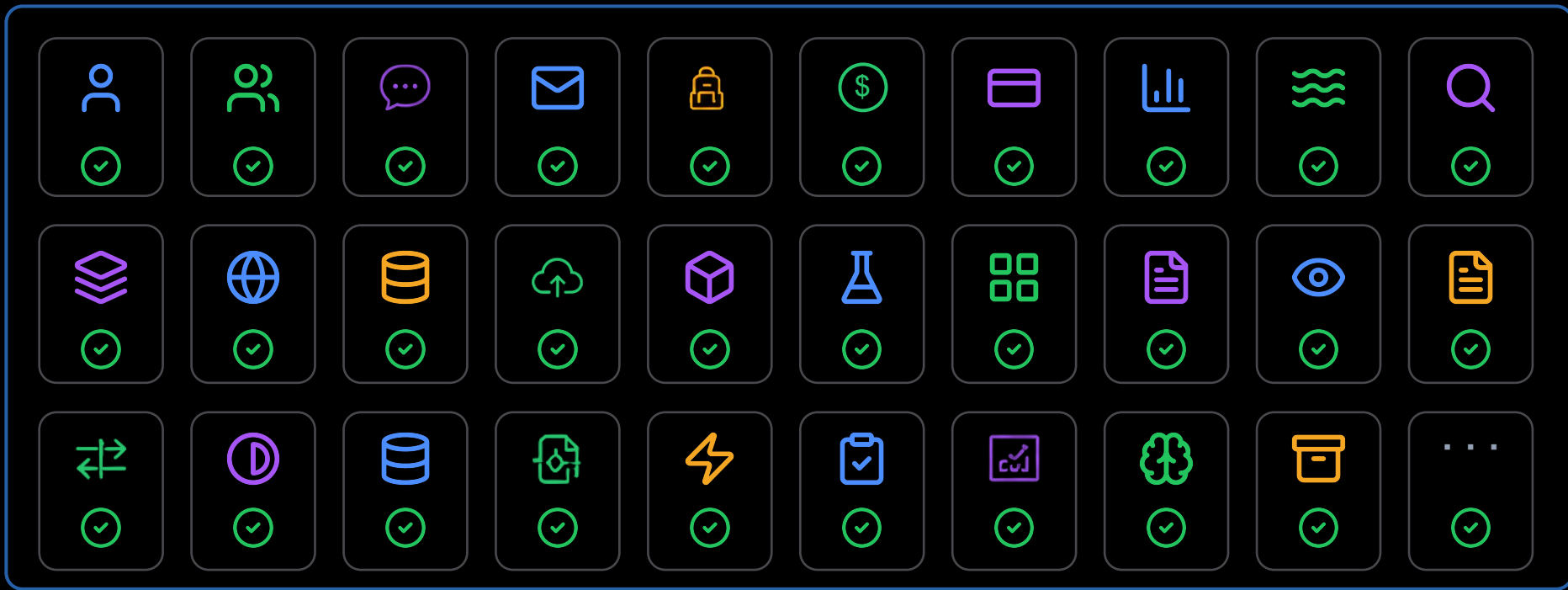
MICROSERVICE SYSTEM, AND IT KEEPS GROWING

Microservices at scale have complexity by design.



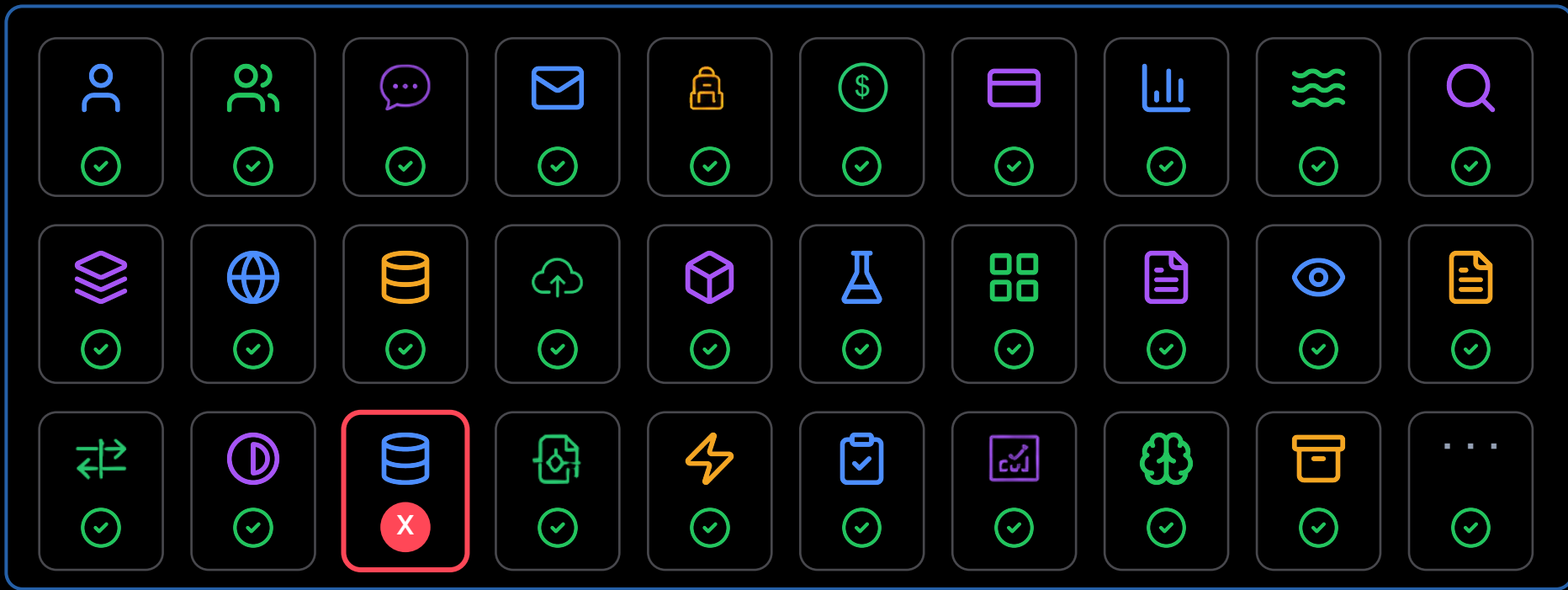
MICROSERVICE SYSTEM, AND IT KEEPS GROWING

Microservices at scale have complexity by design.



MISS ONE, AND IT'S A BREACH

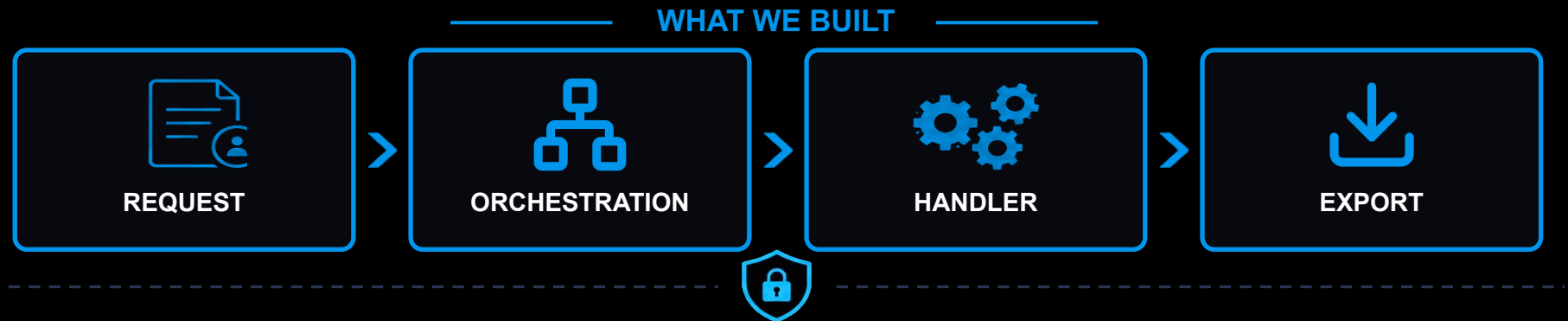
A deletion request must be executed everywhere.



...except one.

Miss one = a breach.

THE MACHINE WE BUILT **IS THE ATTACK SURFACE**



Same machine. Same request.



 The same pipeline that protects data **can be exploited to abuse it.**

REGULATORS **RAISED THE BAR**

“

“We tried.”

USED TO BE ENOUGH



“

“Prove it.”

IS THE NEW STANDARD

WHAT REGULATORS NOW REQUIRE



**Verifiable
Evidence**



**Complete
Audit Trail**



**Consistent
Enforcement**



30-Day Clock



**Increasing
Scrutiny**



At our scale, you can't produce proof by hand. **Infrastructure is the only way.**

THE **REAL** QUESTION

THE CHALLENGE



600+

internal services



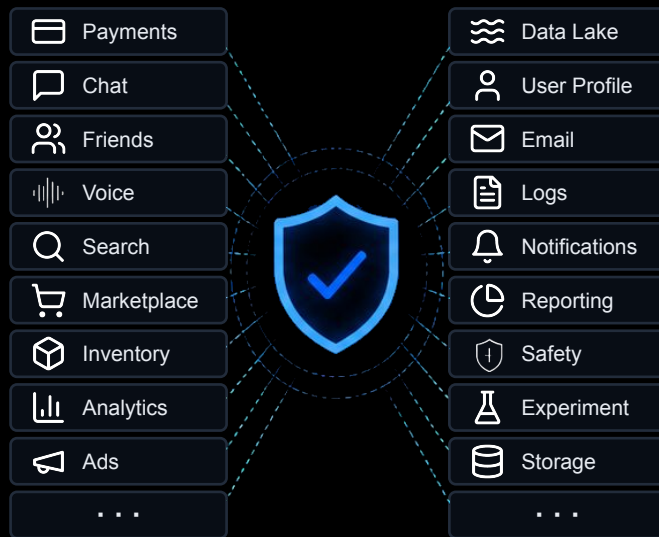
8

data storage systems



~3.5x

increase in privacy
requests YoY



How do you
coordinate a
trustworthy privacy
guarantee across over
600 autonomous
services?



**Legacy Systems
Reached Their Limits.**



**Scale
exploded.**



**Operational
burden grew.**



**Incremental fixes
weren't enough.**

02

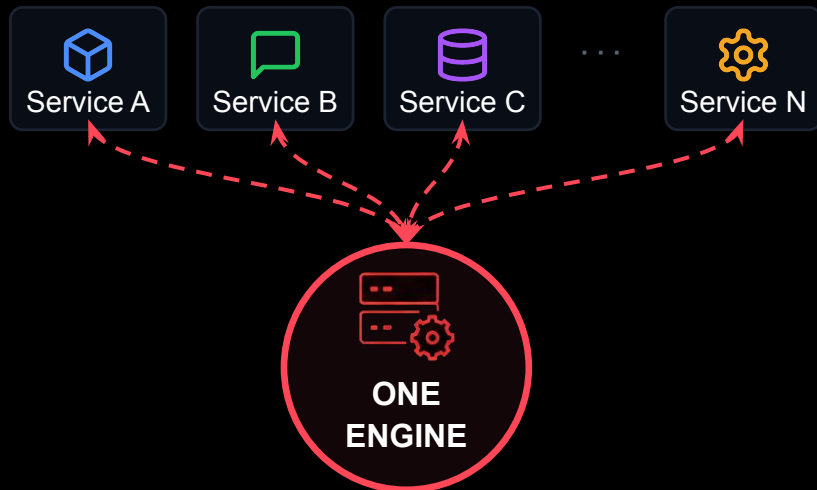
Privacy infrastructure: A Redesigned Federated System

Building the foundation for
privacy at scale.



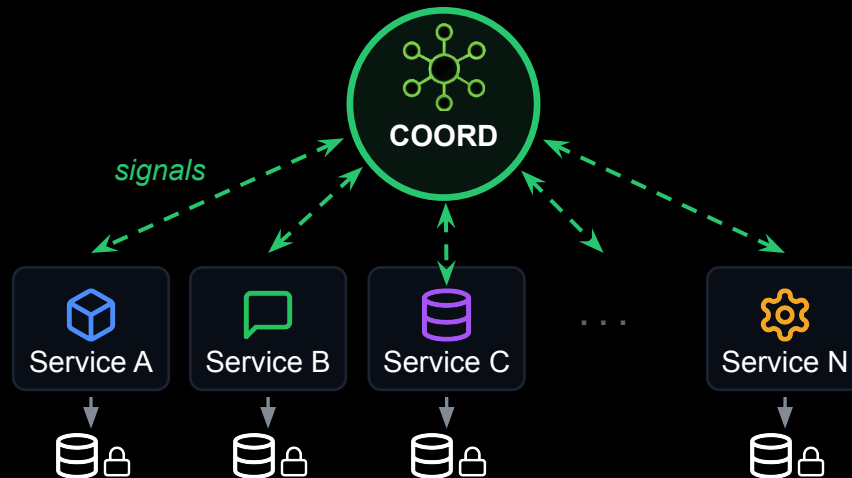
CENTRALIZE **CONTROL FLOW** — NOT DATA

CENTRALIZED — THE NAIVE MODEL



**data in — bottleneck +
single point of failure**

FEDERATED + CENTRAL COORDINATION



**signals out — each owner
acts on its own data**



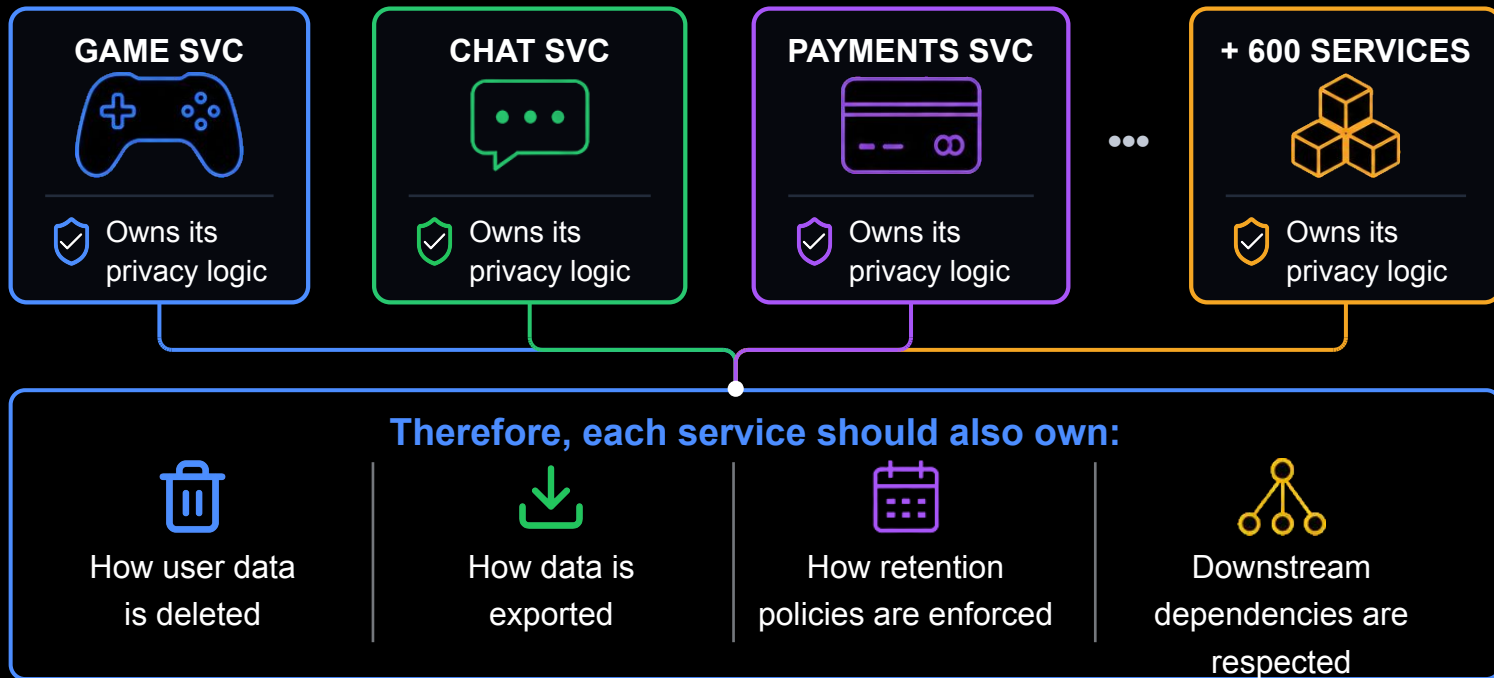
Only signals flow.

Data stays where it belongs.

Autonomy remains.

FEDERATED OWNERSHIP MODEL

Privacy Ownership Follows **Data Ownership**.



PLATFORM

The central platform does not execute logic directly.

Instead, it delegates execution to service-owned privacy handlers.



CENTRAL ORCHESTRATION, **FEDERATED EXECUTION**

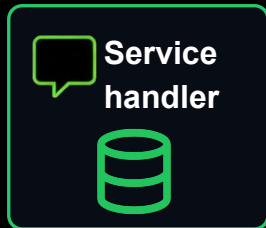


1 request → **600+ sub-tasks**



ORCHESTRATION LAYER

⌘ Temporal workflow engine



...



Asynchronous

Non-blocking
by design



Horizontally Scalable

Handles growth
with ease



Fault-tolerant

Retries, timeouts,
and recovery built-in



Fully Traceable

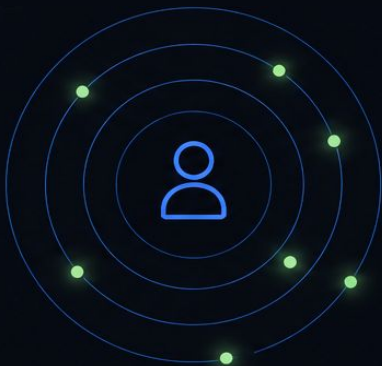
End-to-end visibility
and auditability

PRIVACY STARTS WITH VISIBILITY

“where does this user’s data live?” is now **one query**.

```
> catalog.locate (user=260805)
```

✓ **7 stores found**



-  DynamoDB
-  S3
-  Redis
-  Kafka
-  Postgres
-  Elastic
-  Glacier



CATALOG SNAPSHOT

ID: 89f7a2c1



Owner

Game Platform



PI fields

User's email,
IP address, geolocation



Storage

DynamoDB



Retention policy

7 years



Exemptions

No



One query.
Every location.

Full context.
Daily, org-wide.

Discovery before execution —
you can't delete what you can't find.

DISCOVERY, NOT DELETION.

We bet on the **wrong**
hard problem.

You cannot automate
what you cannot **discover**.



Deletion is easy
once you know.



Discovery is hard
and never static.



Continuous
by design.



Better discovery.
Stronger guarantees.

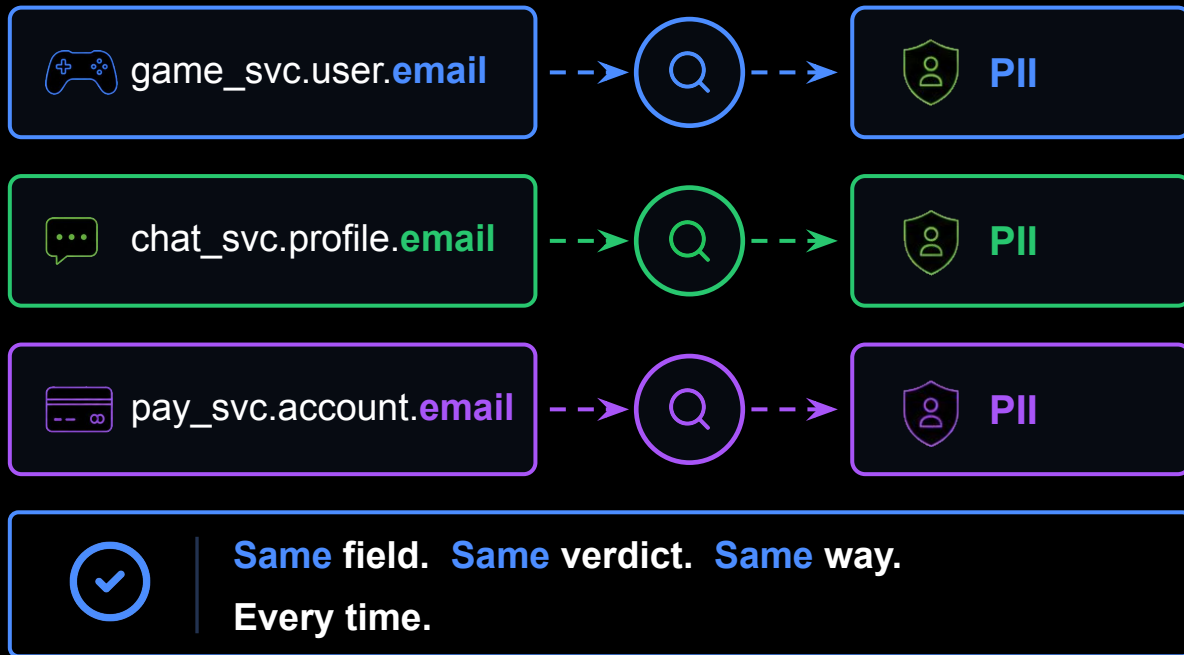
CLASSIFICATION: **ONE DEFINITION**, EVERYWHERE

Discovery says **where**.

Classification says
what it means —
the **same way**,
everywhere.



ONE TAXONOMY.
One Definition of PI.



Consistency



Uniform
Enforcement



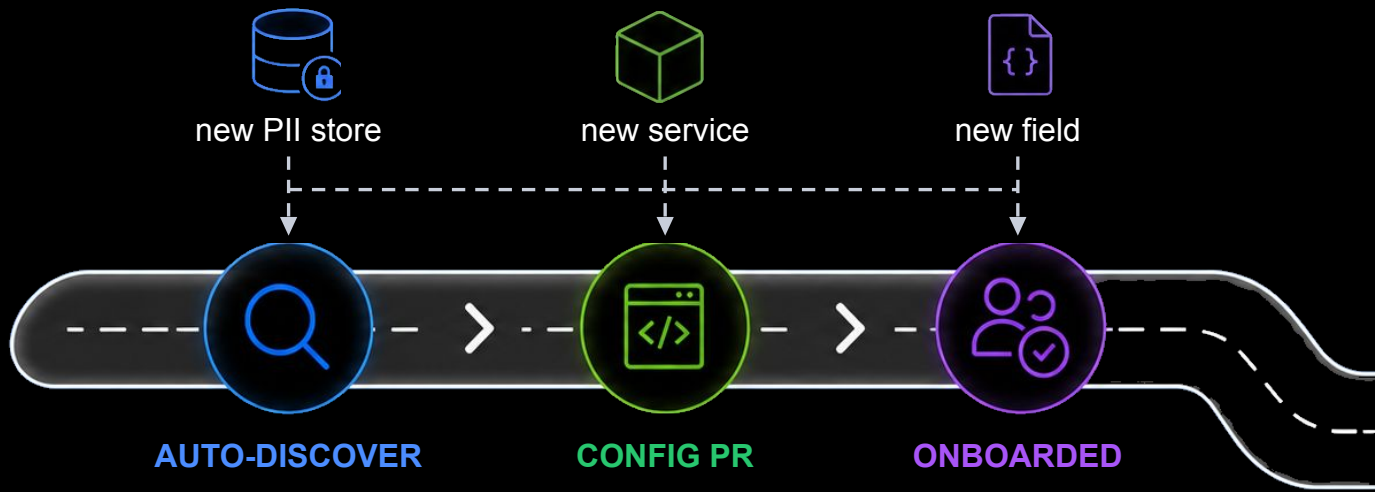
Trustworthy
Automation



Governed & Evolving

GOVERNANCE AS A **PAVED ROAD**

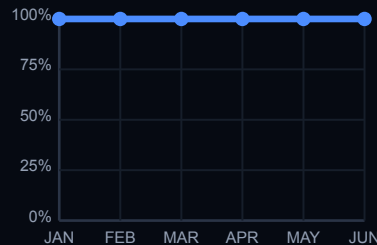
New data appears constantly. Our process keeps coverage near **100%** — and doesn't decay.



COVERAGE THAT STAYS HIGH

~100%

PII DISCOVERY COVERAGE



Near 100%. No decay.

Governance scales.



Always Current



**Self-service
by Design**



**Scales With
Org Growth**

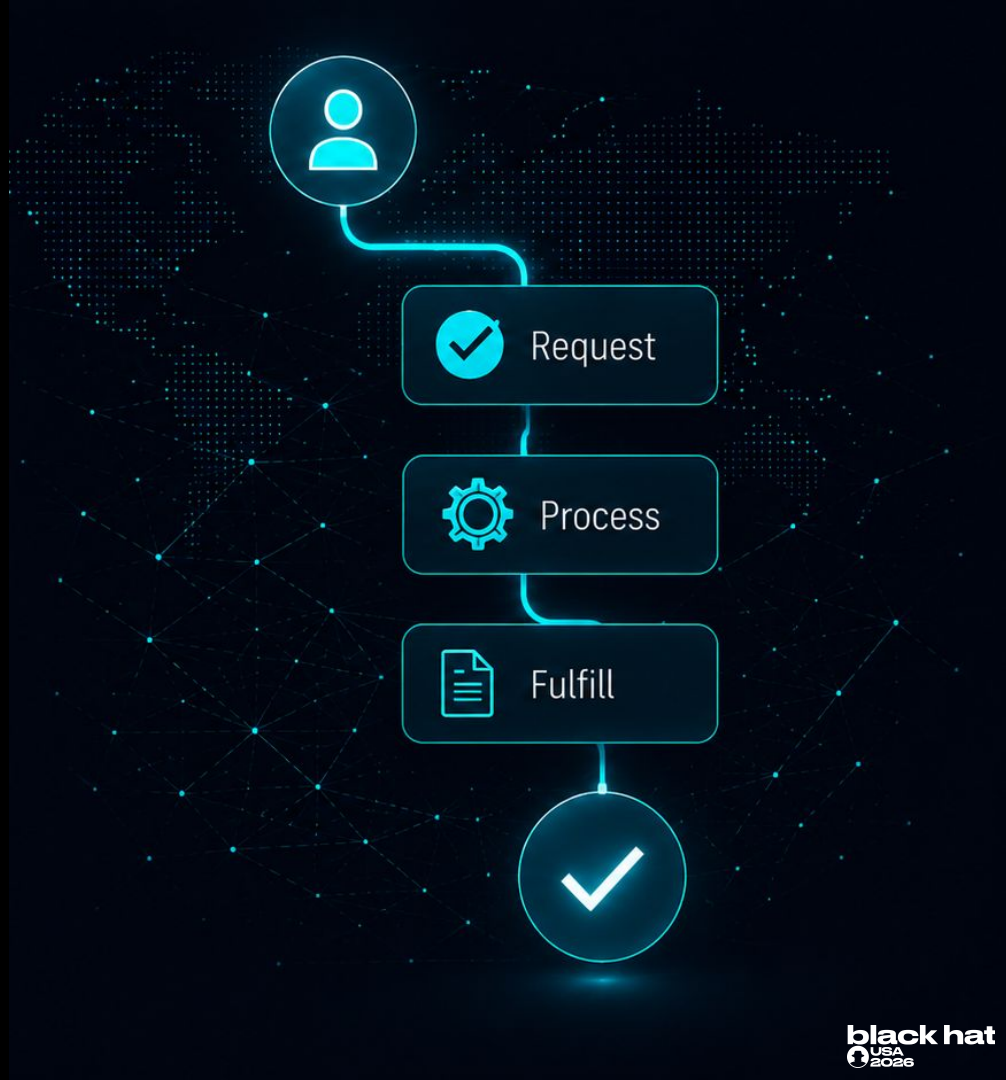


**Stronger
Guarantee**

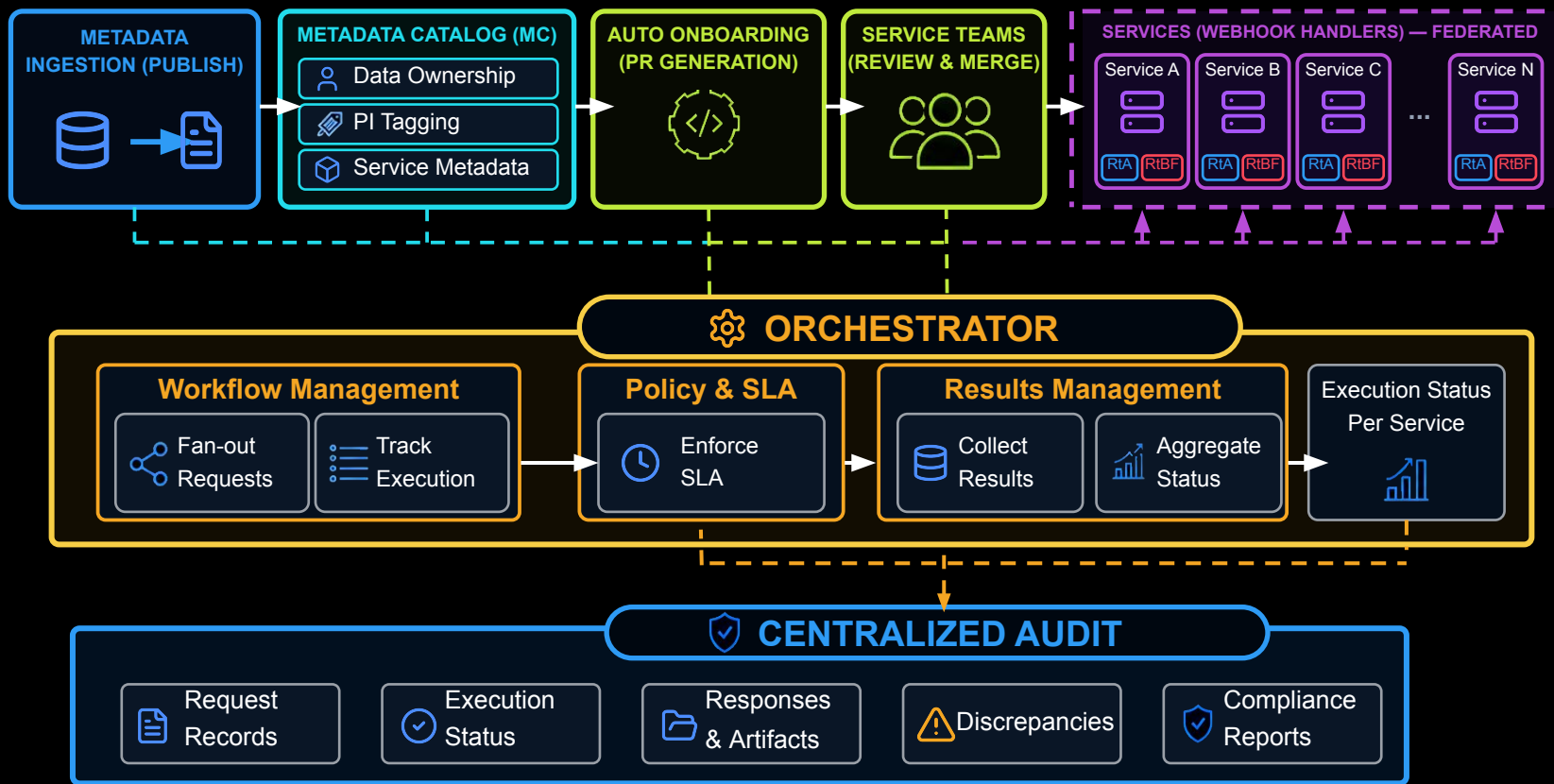
03

New Experience: Privacy Workflows in Distributed Systems

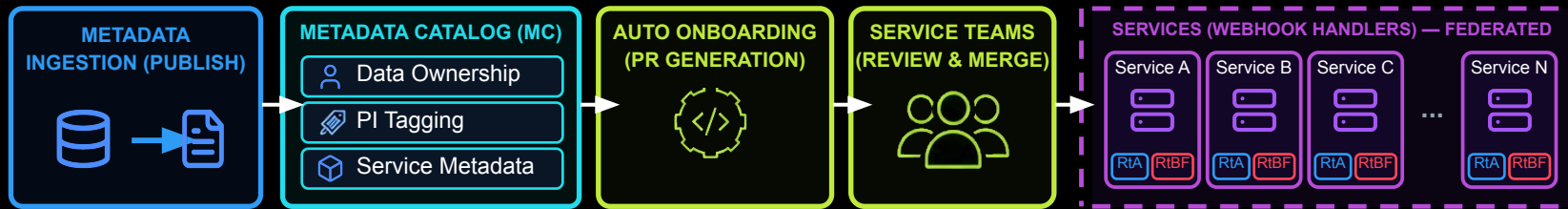
Making privacy seamless
for users and systems.



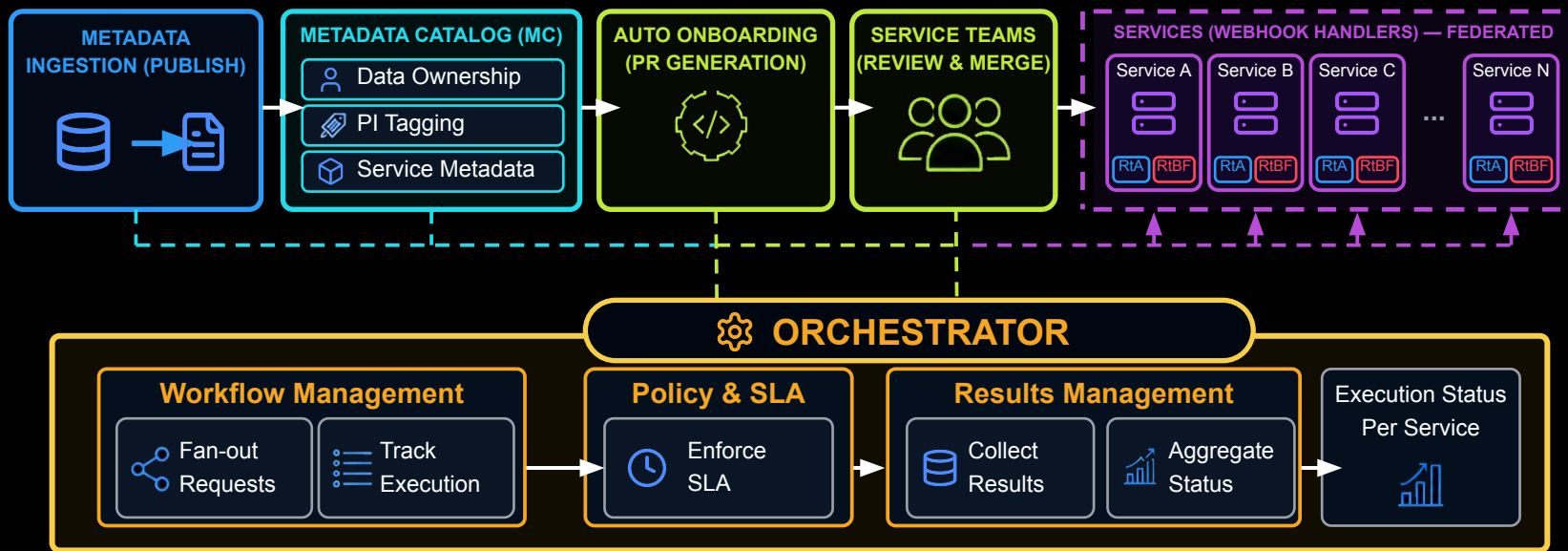
A FEDERATED SOLUTION: FOR **SCALABILITY**



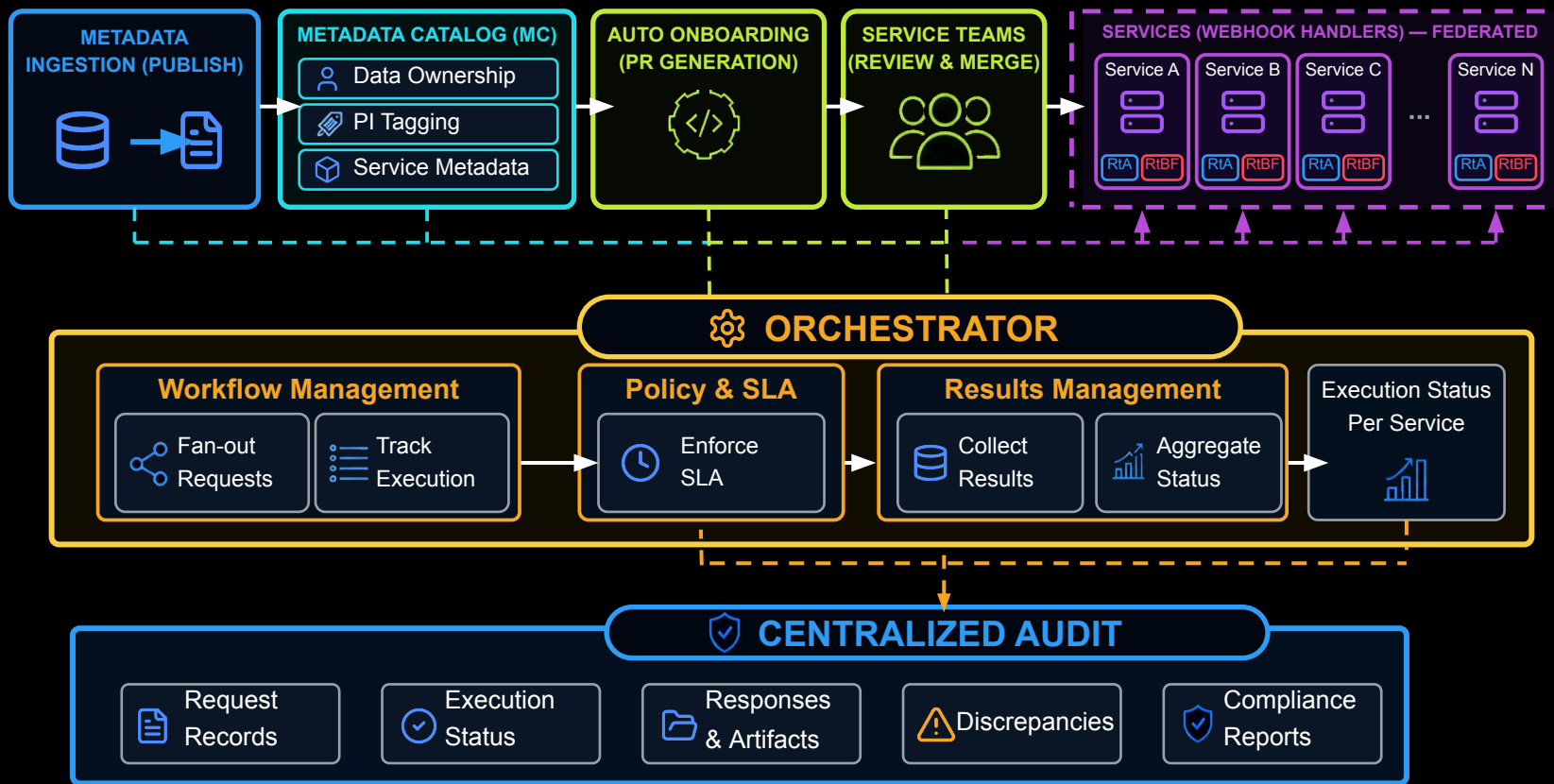
A FEDERATED SOLUTION: FOR **SCALABILITY**



A FEDERATED SOLUTION: FOR **SCALABILITY**



A FEDERATED SOLUTION: FOR **SCALABILITY**



NOBODY WANTS A **PRIVACY** PLATFORM

The system disappears into **three workflows**:



Engineers

Build it. Ship it. Stay fast.



Plug in a SDK / API



Use standard libraries and templates



Get guardrails and defaults out of the box



Focus on features, not compliance



**Privacy is built-in.
No extra work.**



Privacy teams

Operate at scale. Reduce risk.



Central catalog and inventory



Policy management and taxonomy



Monitor coverage and risk in real time



Drive adoption with self-serve



**One source of truth.
Actionable insights.**



Compliance

Prove it. Every time.



End-to-end audit trails



Policy enforcement evidence



Reports in minutes, not weeks



Regulatory ready, always



**Provable, repeatable,
and audit-ready.**

FOR ENGINEERS: A FEW LINES, NOT A PROJECT

Integrate privacy in **minutes**. Not quarters.



Tag your PII



Choose erasure



Choose export



Cover the full footprint



Validated by default

```
PR #4213    add privacy integration    +5 -0    Checks passed

service.yaml

120      ...
121      +   privacy:
122      +     pii: [email, ip_addr, dob]
123      +     erasure: auto key based deletion    # or: custom_api
124      +     export: spark_sql
125      +     includes: [logs, caches, indexes]
126      ...
```

FOR PRIVACY TEAMS: **OPERATE, DON'T COORDINATE**

From chasing tickets to operating the system. | Off the critical path. **In control.**

BEFORE

	ticket · chase service #1	
	ticket · chase service #2	
	ticket · chase service #3	
	ticket · chase service #4	
	ticket · chase service #5	
	ticket · chase service #6	

 **Manual.** Fragmented. You are the bottleneck.

AFTER



PRIVACY CONSOLE



RtBF



in progress



on track



RtA



in progress



on track



failures



none stuck



healthy



Services

600+



Workflows

Auto-fanout



SLA

On track



Reliability

Built-in



Operate the engine. Durable, observable, and scalable workflows.
Generic webhook contract. Any service can join.

A REQUEST IS A **DISTRIBUTED EXECUTION**

One request. Hundreds of services. Five stages. Fully observable.

1

Validate



2-step MFA

2

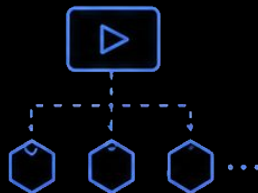
Pre-process



Fraud · Legal · ATO

3

Orchestrate



Register workers

4

Execute



Delete or export

5

Respond



Archive · RtA only



End-to-end visibility



Built for scale



Fault-tolerant



Privacy by design



Measurable

WHAT CHANGED



FROM UNKNOWN TO PROVABLE:

INCOMPLETE DELETION IS NOW **DETECTABLE**.

COVERAGE NEAR

100%

AND DOESN'T DECAY



AUDIT EXPOSURE

BEFORE

Periodic

Sampling

AFTER



Continuous

Evidence



Always ready. Audit anytime.



FULFILLMENT TIME

BEFORE

Days

Often > 3 days

AFTER



Hours

Often < 24 hrs



Faster for users.
Lower operational risk.



ONBOARDING

BEFORE

Falling Behind

Manual,
ticket-driven

AFTER



Self-Service

Auto-discovered,
self-onboarded



Coverage scales with
the organization.



OPERATIONAL RISK

BEFORE

Unknown Gaps

Hard to find,
easy to miss

AFTER



Known &
Actionable

Every gap
is visible



Less risk. More control.
Provable compliance.

FOR COMPLIANCE: **PROOF, NOT PROMISES**

From anxiety to [evidence](#). Every request leaves an audit-grade, immutable receipt.

THE OLD WAY



Did we actually comply?



Email teams



Assemble spreadsheets



Days or weeks



From “Did we comply?”
to “[Here is the proof.](#)”



AUDIT RECEIPT · request #A7F3-2C



IMMUTABLE



type

Right to be Forgotten (erasure)



validated



2-step MFA



validated



checkpoint

fraud · legal · risk — passed



passed



executed

600 services · 0 failures



executed



verified

complete — no residual PII



verified



signed

2026-03-14T09:22Z · immutable

04

Security Discussion: Threats, Reliability, and Trade-offs

Securing the system while
balancing scale and risk.



ONE REQUEST. FOUR HOPS.

the machine we built — from the defender's side

1



REQUEST



2



ORCHESTRATION



3



SERVICE
HANDLER



4



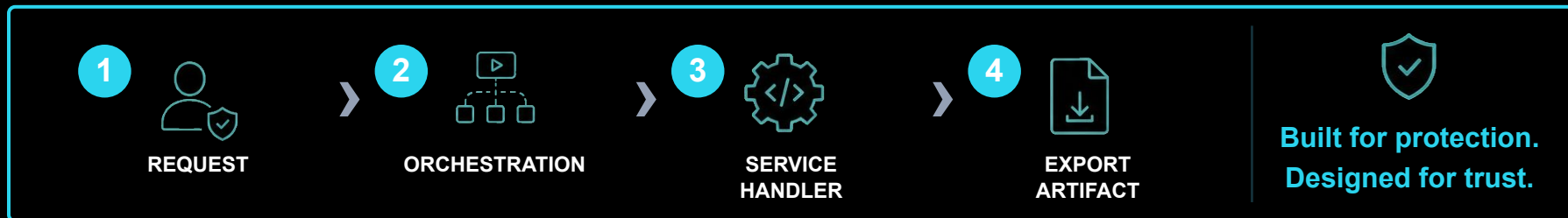
EXPORT
ARTIFACT



**Built for protection.
Designed for trust.**

ONE REQUEST. FOUR HOPS.

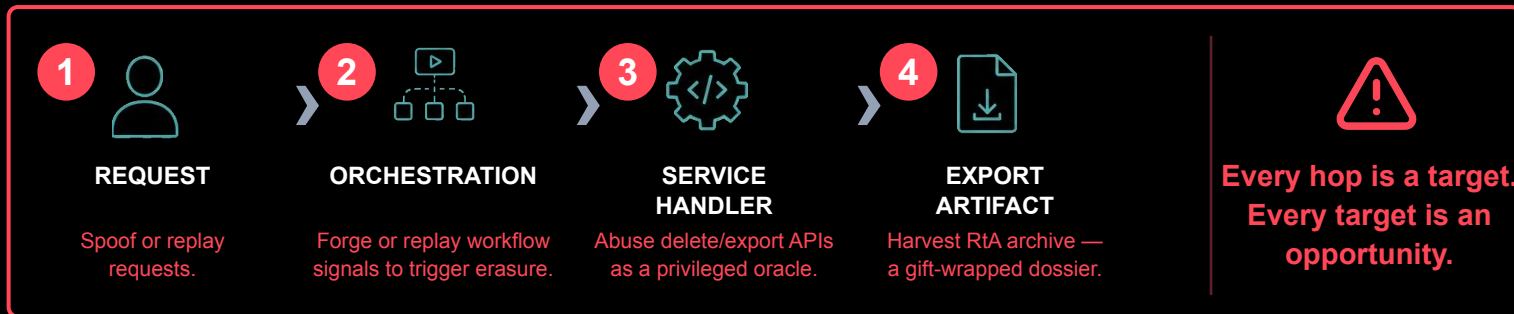
the machine we built — from the defender's side



Same machine. Different intent.



ATTACKER VIEW
FOUR SURFACES.



FOUR WAYS TO WEAPONIZE THE MACHINE

Same machine. Different intent. Same mission: protect users and their data.

1

WEAPONIZED DELETION



Attacker hijacks
an account



File "delete me"



Erases across
600 services

Hijack an account → "delete me" erases them across 600 services.



BLOCKED



ATO signals +
step-up MFA

FOUR WAYS TO WEAPONIZE THE MACHINE

Same machine. Different intent. Same mission: protect users and their data.

1

WEAPONIZED DELETION



Attacker hijacks
an account



File "delete me"



Erases across
600 services

Hijack an account → "delete me" erases them across 600 services.



BLOCKED



ATO signals +
step-up MFA

2

EVIDENCE DESTRUCTION



Abuse the platform
(fraud, harassment, etc.)



Self-delete via
RtBF



Fraud trail
vanishes

Abuse, then self-delete → the fraud trail vanishes.



BLOCKED



Open-investigation
holds

FOUR WAYS TO WEAPONIZE THE MACHINE

Same machine. Different intent. Same mission: protect users and their data.

1

WEAPONIZED DELETION



Attacker hijacks
an account



File "delete me"



Erases across
600 services

Hijack an account → "delete me" erases them across 600 services.



BLOCKED



ATO signals +
step-up MFA

2

EVIDENCE DESTRUCTION



Abuse the platform
(fraud, harassment, etc.)



Self-delete via
RtBF



Fraud trail
vanishes

Abuse, then self-delete → the fraud trail vanishes.



BLOCKED



Open-investigation
holds

3

DATA EXFILTRATION



Stolen session
(high-value account)



Fire "give me
a copy" (RtA)



Full PII
dossier

A stolen session fires "give me a copy" → a full PII dossier.



BLOCKED



Auth + risk checks
+ scoped buckets + audit

FOUR WAYS TO WEAPONIZE THE MACHINE

Same machine. Different intent. Same mission: protect users and their data.

1

WEAPONIZED DELETION



Attacker hijacks an account



File "delete me"



Erases across 600 services

Hijack an account → "delete me" erases them across 600 services.



BLOCKED



ATO signals +
step-up MFA

2

EVIDENCE DESTRUCTION



Abuse the platform
(fraud, harassment, etc.)



Self-delete via
RtBF



Fraud trail
vanishes

Abuse, then self-delete → the fraud trail vanishes.



BLOCKED



Open-investigation
holds

3

DATA EXFILTRATION



Stolen session
(high-value account)



Fire "give me
a copy" (RtA)



Full PII
dossier

A stolen session fires "give me a copy" → a full PII dossier.



BLOCKED



Auth + risk checks
+ scoped buckets + audit

4

THE LEGAL-HOLD TRAP



Account under active
investigation



User files
"delete me"



Tip them off
(or lose evidence)

Delete mid-investigation → destroy evidence, or tip them off.



BLOCKED



Legal holds
block it silently

NO SOFT INTERIOR



AUTHN / AUTHZ



Every handler authenticates.



Every orchestration message is signed and scoped.



IDEMPOTENCY



Everything retries.



Every action is safe to run twice.



No double-execution.
No partial-state corruption.



INTEGRITY



No over-deletion.



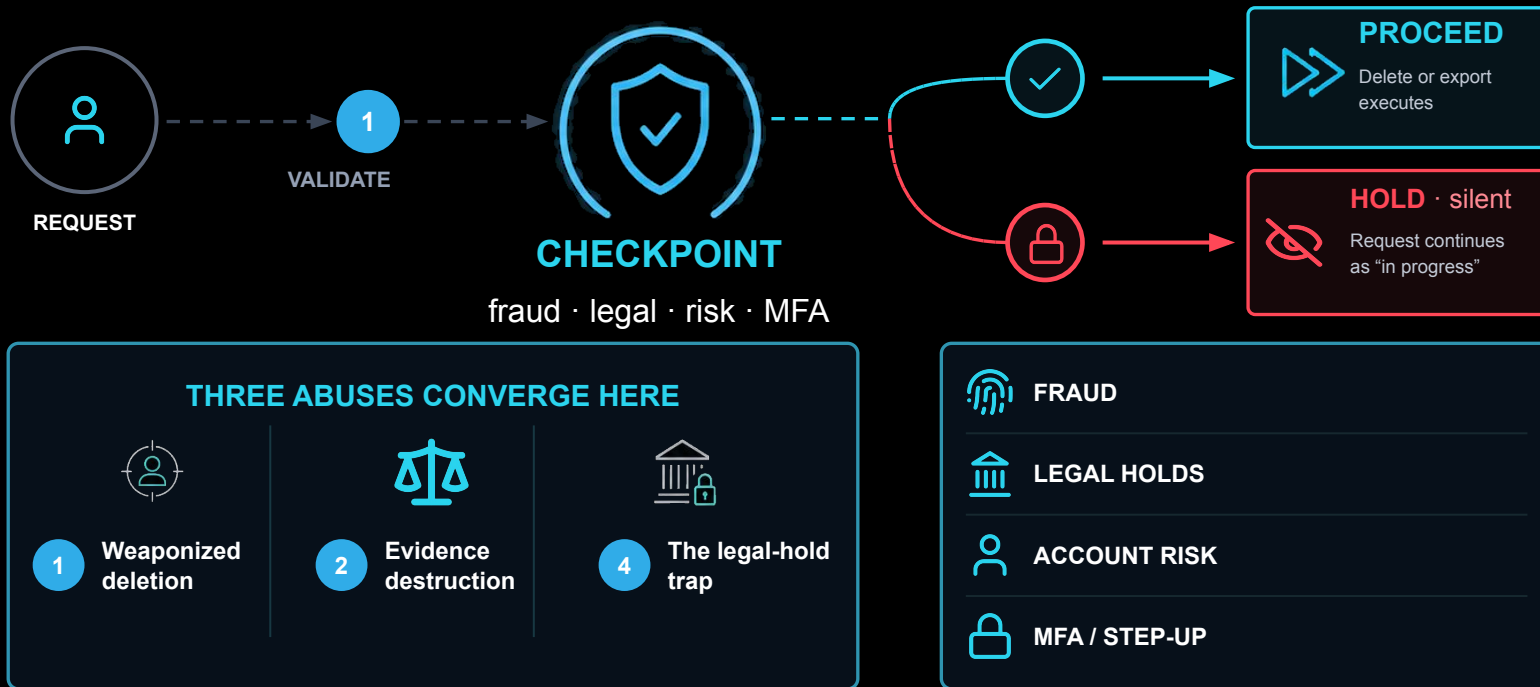
No under-deletion.



Correct entity.
Correct scope.

THREE OF FOUR ABUSES STOP AT ONE GATE

Do the dangerous thinking **ONCE**, at a single preprocessing checkpoint.

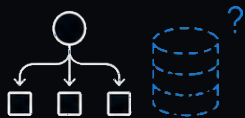


EVERY SCALABILITY WIN IS A SECURITY COST

SCALABILITY WIN	WHAT WE GAINED	SECURITY COST
 Federated ownership →	 Horizontal scale, team autonomy, parallel delivery. →	 Distributed attack surface.
 Service flexibility →	 Services choose how to integrate and evolve. →	 More contracts to validate.
 Automation speed →	 High throughput, faster fulfillment. →	 More to authenticate.
 Platform scale →	 Platform grows with users and services. →	 Larger blast radius.

LESSON LEARNED: WHAT WE GOT WRONG FIRST

1



We **orchestrated**
before we could **discover**



Execution is blind without an accurate inventory.
We learned that the hard, embarrassing way.

2



We treated **ownership**
as optional



If a datastore has no owner, no one is accountable for its privacy posture.
Unowned data is where breaches hide.

3



We bolted **privacy**
on downstream



Privacy can't be a downstream compliance gate.
It must live IN the engineering workflow.
PR-in-the-repo is why teams actually comply.

TWO MORE WORTH SAYING



- ✓ Prefer **self-service** over central review — queues become bottlenecks.
- ✓ **Automation** is only as good as your **inventory** — stale data means errors amplified at scale.

THE BOTTOM LINE



Good privacy at scale isn't magic.
It's inventory, ownership, workflow, and alignment done consistently.

05

Future work & Conclusion

Where we're headed and
what we've learned.



Looking Ahead



Scaling
Impact



Continuous
Innovation



Privacy by
Design

WHERE THE FRONTIER STILL IS

Not a roadmap. Open problems. **You might be the ones to solve them.**

STILL HARD



SHADOW DATA

Systems we don't yet know exist, drifting out of governance.



STILL HARD



CLASSIFICATION AT SCALE

Accurate, consistent labeling across genuinely messy storage.



OPEN



UNIFIED GOVERNANCE

One control plane across storage, pipelines, analytics — still fragmented today.



THE ATTACK SURFACE KEEPS GROWING. THE DEFENSE HAS TO KEEP GROWING WITH IT.

THE TAKEAWAY



PRIVACY RIGHTS REQUIRE **INFRASTRUCTURE** — NOT JUST POLICY.



That “**Delete me.**” we opened with?

Now: safe · complete · provable.



Can your systems answer these — **continuously, by design?**



What data
do we have?



Where is it
stored?



Who owns
it?



How long should
it exist?



A POLICY MAKES A PROMISE.

INFRASTRUCTURE KEEPS IT.

Thank you!



PRIVACY AT SCALE

Roblox's Infrastructure for
Honoring User Privacy Rights

Hao Zhang

[linkedin.com/in/haozhangcs](https://www.linkedin.com/in/haozhangcs)

Yiwen Luo

[linkedin.com/in/yiwen-luo](https://www.linkedin.com/in/yiwen-luo)

